

Chapter- 3

Scanning and Enumeration

CE– TE– Ethical Hacking

Dr. Ujwala Ravale

Assistant professor
Dept. of Computer Engineering
SIES Graduate School of Technology

Chapter content

- **3.1** Scanning fundamentals, Types of scanning (Active and Passive)
- **3.2** Network Scanning, Vulnerability Scanning, Identifying, Live Systems and Open Ports, Scanning Techniques: TCP/UDP Scans, SYN Scans, scanning tools
- **3.3** Enumeration Fundamentals, Enumeration techniques and tools, Enumeration Countermeasures

Scanning

- The identification of active machines is accomplished by means of ping sweeps and port scans.
- Both aid in an analysis of understanding whether the machine is actively connected to the network and reachable.
- After all details of a network and its operations have been recorded, the attacker can then identify vulnerabilities that could possibly allow access or act as an entry point.

Host Discovery

- Attackers will want to know whether machines are alive before they attempt to attack.
- One of the most basic methods of identifying active machines is to perform a ping sweep.
- Ping uses ICMP and works by sending an echo request to a system and waiting for the target to send an echo reply back.
- If the target device is unreachable, a request timeout is returned.
- Ping is a useful tool to identify active machines and to measure the speed at which packets are moved from one host to another or to get details like the TTL.

Host Discovery

- **Figure** shows a capture of ping packets from a Linux system using the Wireshark packet capture (sniffer) tool.
- If you examine the ASCII decode at the bottom, you will notice that the data in the ping packet is composed of different hexadecimal values;
- In other systems (like Windows), this may be different.
- The reason is that the RFC that governs ping doesn't specify what's carried in the packet as payload.
- Vendors fill in this padding as they see fit.
- Unfortunately, this can also serve hackers as a covert channel.
- Hackers can use a variety of programs to place their own information in place of the normal padding.
- Tools like Loki and IcmpSendEcho are designed for just this purpose.
- Pings are actually a series of messages entering and leaving the network.



Tools

- Angry IP Scanner: <https://angryip.org>
- MASSCAN: <https://github.com/robertdavidgraham/masscan>
- Hping3: <https://tools.kali.org/information-gathering/hping3/>
- WS_Ping ProPack: <https://ws-ping-propack.en.softonic.com/>
- Nmap: <https://nmap.org/>

Port and Service Discovery

- Port scanning is the process of connecting to TCP and UDP ports for the purpose of finding what services and applications are running on the target device.
- After discovering running applications, open ports, and services, a hacker can then determine the best way to attack the system.
- There are a total of 65,535 TCP and UDP ports.
- These port numbers are used **to identify a specific process** that a message is coming from or going to.

Common Ports and Protocols

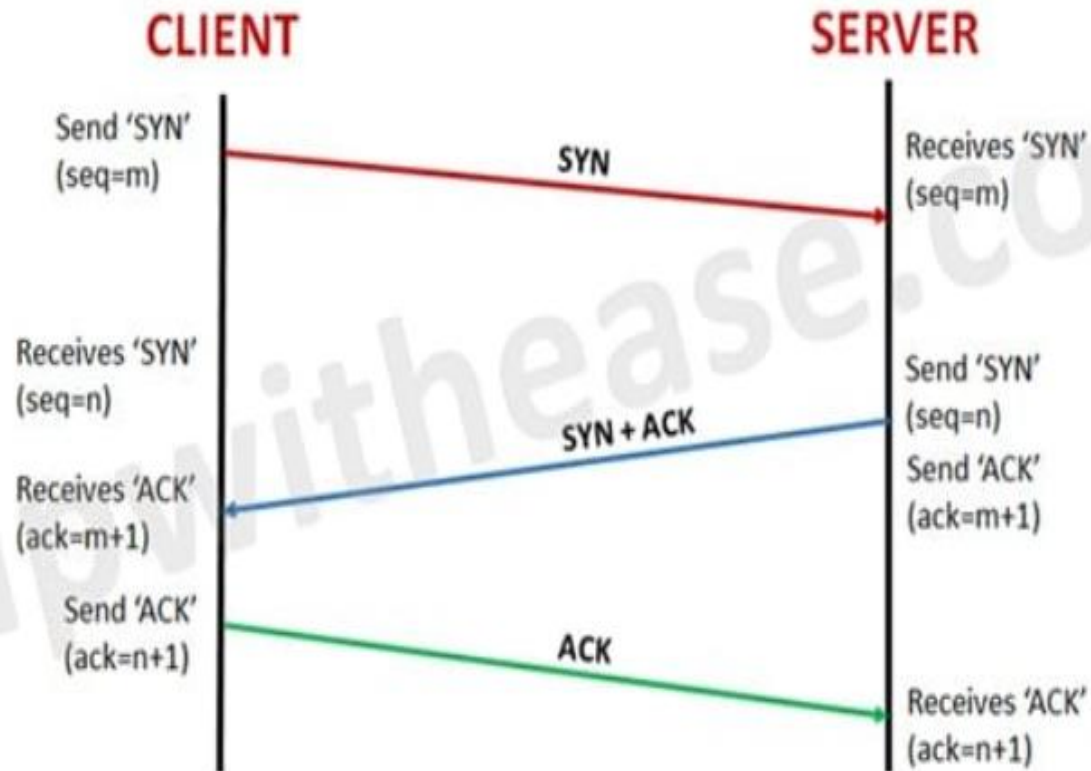
Port	Protocol	Service/Transport
20/21	FTP	TCP
22	SSH	TCP
23	Telnet	TCP
25	SMTP	TCP
53	DNS	TCP/UDP
69	TFTP	UDP
80	HTTP	TCP
110	POP3	TCP
135	RPC	TCP
161/162	SNMP	UDP
1433/1434	MSSQL	TCP

Port and Service Discovery

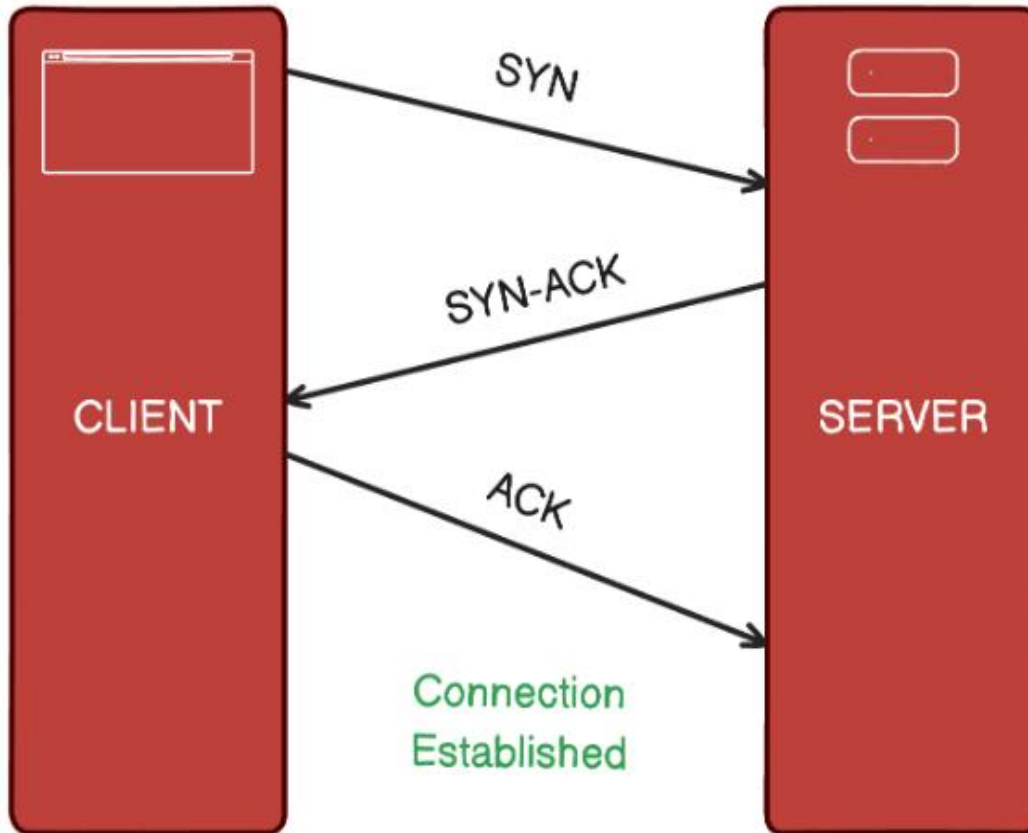
- These applications run on TCP, others on UDP.
- Although it is certainly possible to scan for all **65,535 TCP** and **65,535 UDP** ports, many hackers will not.
- They will concentrate on the **first 1,024 ports** because ports 0–1,023 are the standard ports.
- These well-known ports are where **we find most of the commonly used applications.**
- This is not to say that high-order ports should be totally ignored, because hackers might break into a system and open a high-order port, such as **31337, to use as a backdoor.**

TCP 3-Way handshake Process

(Connection Establishment)



TCP 3-Way Handshake



SYN

```
Source IP: Client's IP
Source Port: Client's Port
Destination IP: Server's IP
Destination Port: Server's Port
Flags: SYN
Sequence Number: 1000
```

SYN-ACK

```
Source IP: Server's IP
Source Port: Server's Port
Destination IP: Client's IP
Destination Port: Client's Port
Flags: SYN, ACK
Sequence Number: 5000
Acknowledgment Number: 1001
(Client ISN + 1)
```

ACK

```
Source IP: Client's IP
Source Port: Client's Port
Destination IP: Server's IP
Destination Port: Server's Port
Flags: ACK
Acknowledgment Number: 5001
(Server ISN + 1)
```

TCP Connection

- TCP offers robust communication and is considered a connection protocol.
- TCP establishes a connection by using what is called a **three-way handshake**. Those three steps proceed as follows:
- The client sends the server a **TCP packet with the sequence number flag (SYN flag) set and an initial sequence number (ISN)**.
- The server replies by sending a packet with the **SYN/ACK flag** set to the client.
- The synchronize sequence number flag informs the client that it would like to communicate with it, and the acknowledgment flag informs the client that it received its initial packet.
- The **acknowledgment number will be one digit higher** than the client's ISN.
- The server generates an ISN, as well, to keep track of every byte sent to the client.
- When the client receives the server's packet, it creates an ACK packet to acknowledge that the data has been received from the server. At this point, communication can begin.

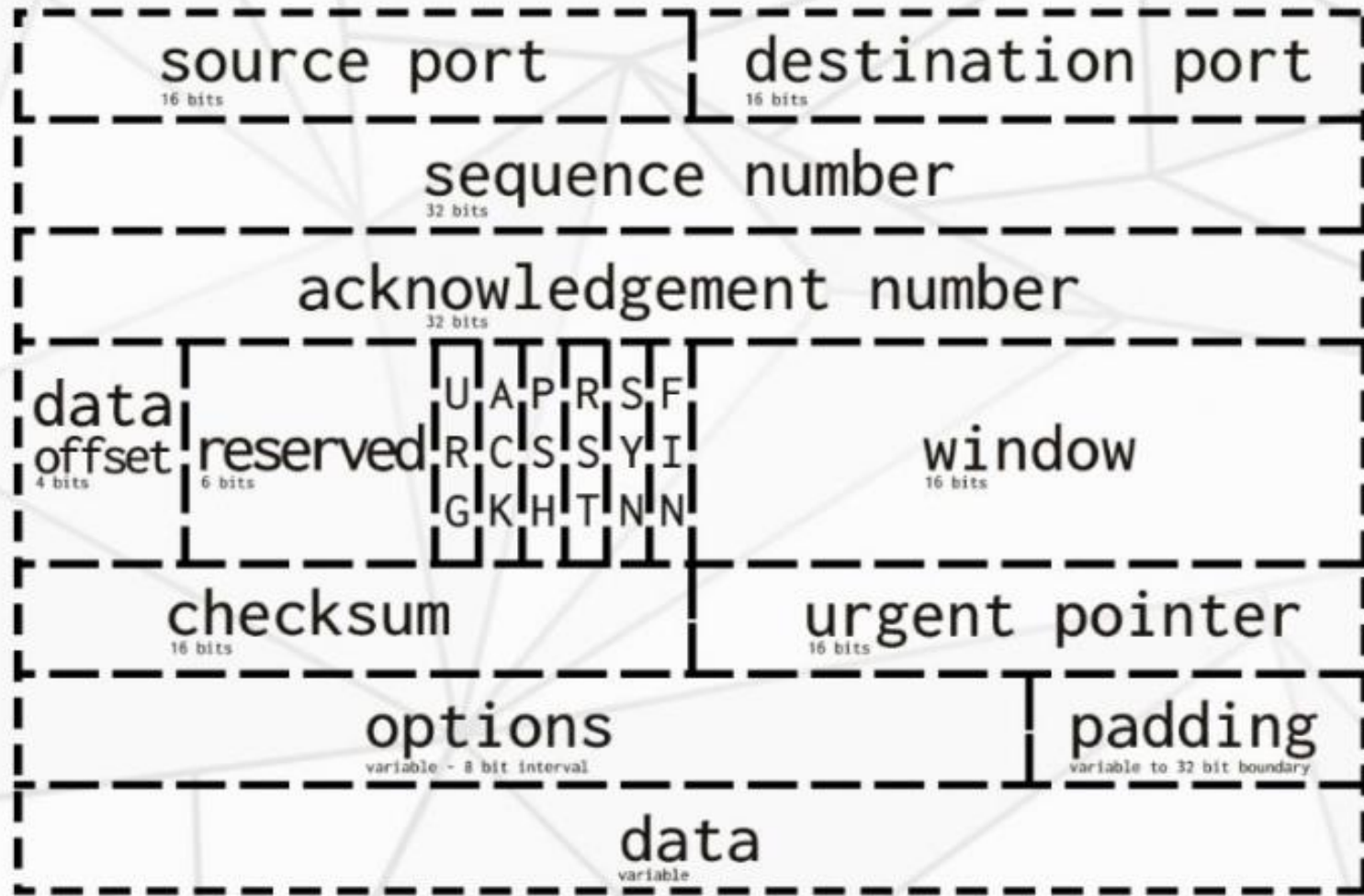
TCP Flag Types

Flag	Description
URG	Urgent data bit used to signify that urgent control characters are present in this packet that should have priority
ACK	Acknowledgment of packets received
PSH	Push data bit used to signal that data in the packet should be pushed to the beginning of the queue; usually indicates an urgent message
RST	Reset bit used to close an abnormal connection
SYN	Synchronize and initial sequence number (ISN)
FIN	Final data flag used during the four-step shutdown of a session

TCP Communication

- The client sends the server a packet with the FIN/ACK flags set.
- The server sends a packet ACK flag set to acknowledge the client's packet.
- The server then generates another packet with the FIN/ACK flags set to inform the client that it also is ready to conclude the session.
- The client sends the server a packet with the ACK flag set to conclude the session.

tcp header format

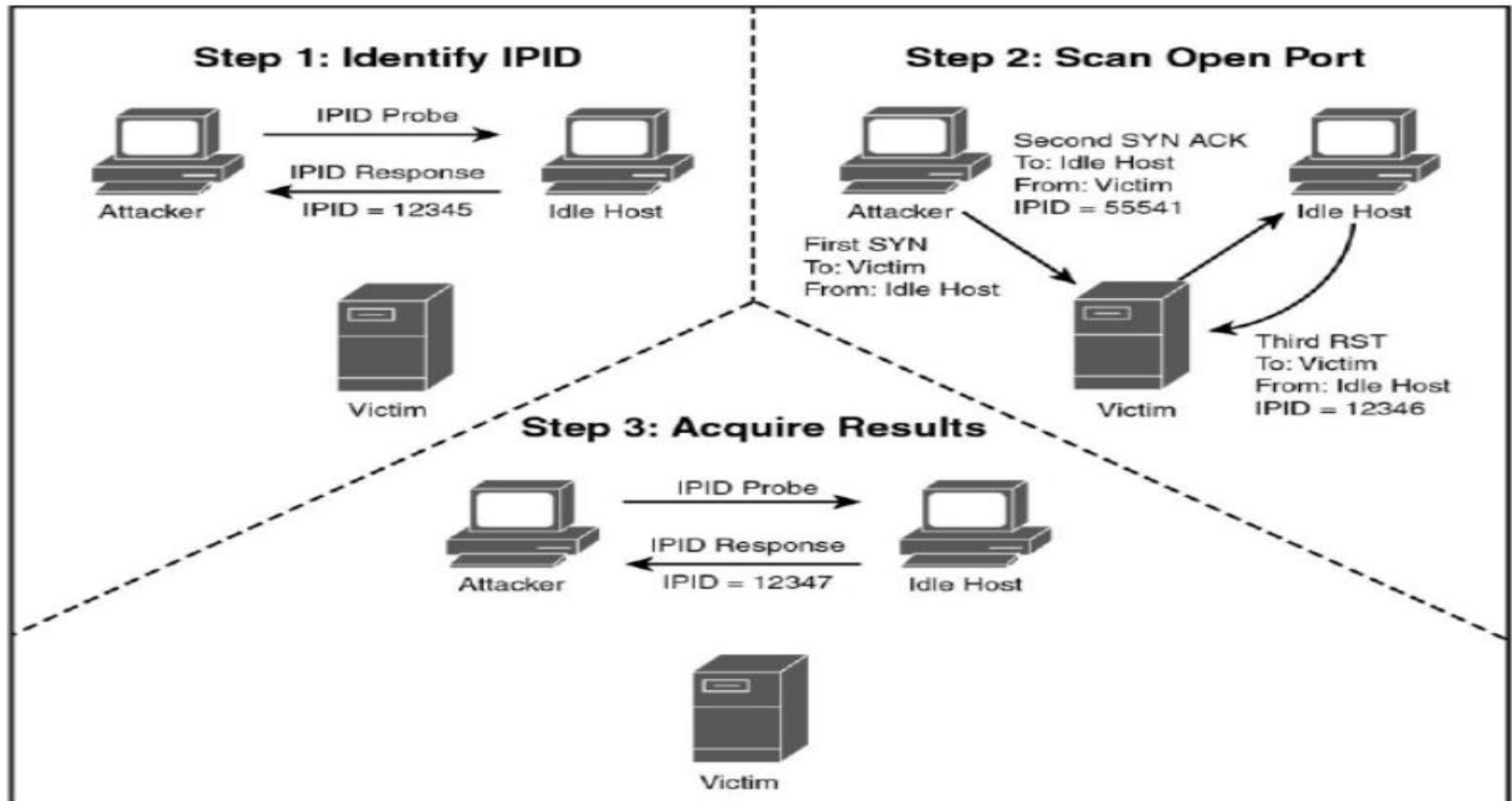


port-scanning techniques

- **TCP full connect scan:** This type of scan is the most reliable, although it is also the most detectable. It is easily logged and detected because a full connection is established. Open ports reply with a SYN/ACK, and closed ports respond with an RST/ACK.
- **TCP SYN scan:** This type of scan is known as **half-open** because a full TCP three-way connection is not established. This type of scan was originally developed to be stealthy and evade IDSs, although most now detect it. Open ports reply with a SYN/ACK, and closed ports respond with an RST/ACK.
- **TCP FIN scan:** Forget trying to set up a connection; this technique jumps straight to the shutdown. This type of scan sends a FIN packet to the target port. An open port should return **no response**. Closed ports should send back an **RST/ACK**. This technique is usually effective only on UNIX devices or those compliant to RFC 793.

port-scanning techniques

- **TCP NULL scan:** Sure, there should be some type of flag in the packet, but a NULL scan sends a packet with no flags set. If the OS has implemented TCP per RFC(Request for Comments 793, open ports send no reply, whereas closed ports will return an RST.
- **TCP ACK scan:** This scan attempts to determine access control list (ACL) rule sets or identify if a firewall or simply stateless inspection is being used. A stateful firewall should return no response. If an ICMP destination is unreachable, and a communication administratively prohibited message is returned, the port is considered to be filtered. If an RST is returned, no firewall is present.
- **TCP XMAS scan:** Sorry, there are no Christmas presents here, just a port scan that has toggled on the FIN, URG, and PSH flags. Open ports should not respond. Closed ports should return an RST. Systems must be designed per RFC 793 for this scan to work, as is common for Linux. It does not work against Windows computers.



Other types of Scan

- **ACK scan:** Sends an ACK probe with random sequence numbers. ICMP type 3 code 13 responses may mean that stateless firewalls are being used, and an RST can mean that the port is not filtered.
- **FTP bounce scan:** Uses an FTP server to bounce packets off and make the scan harder to trace.
- **RPC scan:** Attempts to determine whether open ports are RPC ports.
- **Window scan:** Similar to an ACK scan but can sometimes determine open ports. It does so by examining the TCP window size of returned RST packets. On some systems, open ports return a positive window size and closed ones return a zero window size.

Hping

- Hping is another very useful ethical hacking tool that can perform both ping sweeps and port scans.
- Hping works on Windows and Linux computers and can function as a packet builder.
- You can find the Hping tool at <http://www.hping.org> or download the Linux Backtrack distribution, which also contains Hping. Hping2 and 3 can be used for firewall testing, identifying honeypots, and port scanning.
- Here are some other Hping3 syntax examples of note:
 - ICMP pings: `hping3 -C IP_Address`
 - SYN scan: `hping3 -S IP_Address`
 - ACK scan: `hping3 -A IP_Address`
 - XMAS scan: `hping3 -X IP_Address`

Enumeration

- A technique of extracting valid usernames, machine names, directory names, and so on, from a system.
- Enumeration gives attackers a lot of information that can be used to exploit vulnerabilities.
- Enumeration collects detailed information about a target system, such as the operating system and network details.
- Enumeration can be used offensively and defensively.
- Enumeration is important in ethical hacking because it gives hackers the necessary information that can be used to launch an attack.

Enumeration

- Enumeration is a crucial phase of cybersecurity assessment where an attacker or security tester actively **gathers detailed information from a target system, network or application.**
- Unlike passive reconnaissance, enumeration establishes direct interaction with the target to extract valuable data.
- Discovers users, services, open ports, shared resources, operating system details and network infrastructure.
- Identifies misconfigurations, exposed services, trust relationships and potential attack vectors for further assessment.

.

Types of Enumeration

1. NetBIOS Enumeration:

- NetBIOS (Network Basic Input/Output System) enumeration is commonly associated with **Windows environments**.
- It is used to collect information about systems, domains, shared resources and users over TCP/IP networks.
- NetBIOS enumeration reveals computer names, workgroups/domains, logged-in users, shared resources and network services.
- NetBIOS commonly uses **Port 139** and the nbtstat utility (e.g., nbtstat -h) is used to view NetBIOS information and available command parameters.
- **Mitigation:** Disable NetBIOS if not required, restrict SMB/file sharing, block NetBIOS traffic through firewalls and enforce secure access policies.

NetBIOS Enumeration

```
C:\Users\gfg1124>nbtstat -h
```

Displays protocol statistics and current TCP/IP connections using NBT (NetBIOS over TCP/IP).

```
NBTSTAT [ [-a RemoteName] [-A IP address] [-c] [-n]
          [-r] [-R] [-RR] [-s] [-S] [interval] ]
```

- a (adapter status) Lists the remote machine's name table given its name
- A (Adapter status) Lists the remote machine's name table given its IP address.
- c (cache) Lists NBT's cache of remote [machine] names and their IP addresses
- n (names) Lists local NetBIOS names.
- r (resolved) Lists names resolved by broadcast and via WINS
- R (Reload) Purges and reloads the remote cache name table
- S (Sessions) Lists sessions table with the destination IP addresses
- s (sessions) Lists sessions table converting destination IP addresses to computer NETBIOS names.
- RR (ReleaseRefresh) Sends Name Release packets to WINS and then, starts Refresh

RemoteName Remote host machine name.
IP address Dotted decimal representation of the IP address.
interval Redisplays selected statistics, pausing interval seconds between each display. Press Ctrl+C to stop redisplaying statistics.

NetBIOS Enumeration

- **Tools and Techniques:**
- # NetBIOS enumeration with nmap
- `nmap -sU -p 137 --script nbstat target-ip`
- # NetBIOS name lookup
- `nbtscan target-ip`
- # Enumerate NetBIOS shares
- `smbclient -L //target-ip -N`
- # Net command enumeration (Windows)
- `net view \\target-ip`
- `net use \\target-ip\ipc$ "" /user:"`

- # Step 1: Find NetBIOS information
- `nmap -sU -p 137 --script nbstat 192.168.1.20`

- # Step 2: Perform NetBIOS lookup
- `nbtskan 192.168.1.20`

- # Step 3: Enumerate SMB shares
- `smbclient -L //192.168.1.20 -N`

nmap -sU -p 137 --script nbstat 192.168.1.20

Starting Nmap 7.94

Nmap scan report for 192.168.1.20

Host is up (0.0020s latency).

PORT	STATE	SERVICE
137/udp	open	netbios-ns

Host script results:

```
| nbstat:  
| NetBIOS name: OFFICE-PC  
| NetBIOS user: Administrator  
| NetBIOS MAC: 00-15-5D-4A-21-90  
| Names:  
| OFFICE-PC <00> UNIQUE  
| WORKGROUP <00> GROUP  
| OFFICE-PC <20> UNIQUE  
|
```

MAC Address: 00:15:5D:4A:21:90

Nmap done: 1 IP address scanned

nbtscan 192.168.1.20

Doing NBT name scan for addresses from 192.168.1.20

IP address	NetBIOS Name	Server	User
192.168.1.20	OFFICE-PC	<server>	ADMIN-PC

MAC address:
00-15-5D-4A-21-90

Adapter address:
00-15-5D-4A-21-90

Node Status:

Name	Type
OFFICE-PC	UNIQUE
WORKGROUP	GROUP
OFFICE-PC	UNIQUE

smbclient -L //192.168.1.20 -N

Anonymous login successful

- **-L → List available shares**
- **-N → Attempt anonymous login (no password)**

Sharename	Type	Comment
-----	----	-----
ADMIN\$	Disk	Remote Admin
C\$	Disk	Default Share
Public	Disk	Public Documents
Shared	Disk	Department Files
IPC\$	IPC	IPC Service

Server	Comment
-----	-----
OFFICE-PC	Windows 10 Professional

Workgroup	Master
-----	-----
WORKGROUP	OFFICE-PC

net view \\192.168.1.20

Shared resources at \\192.168.1.20

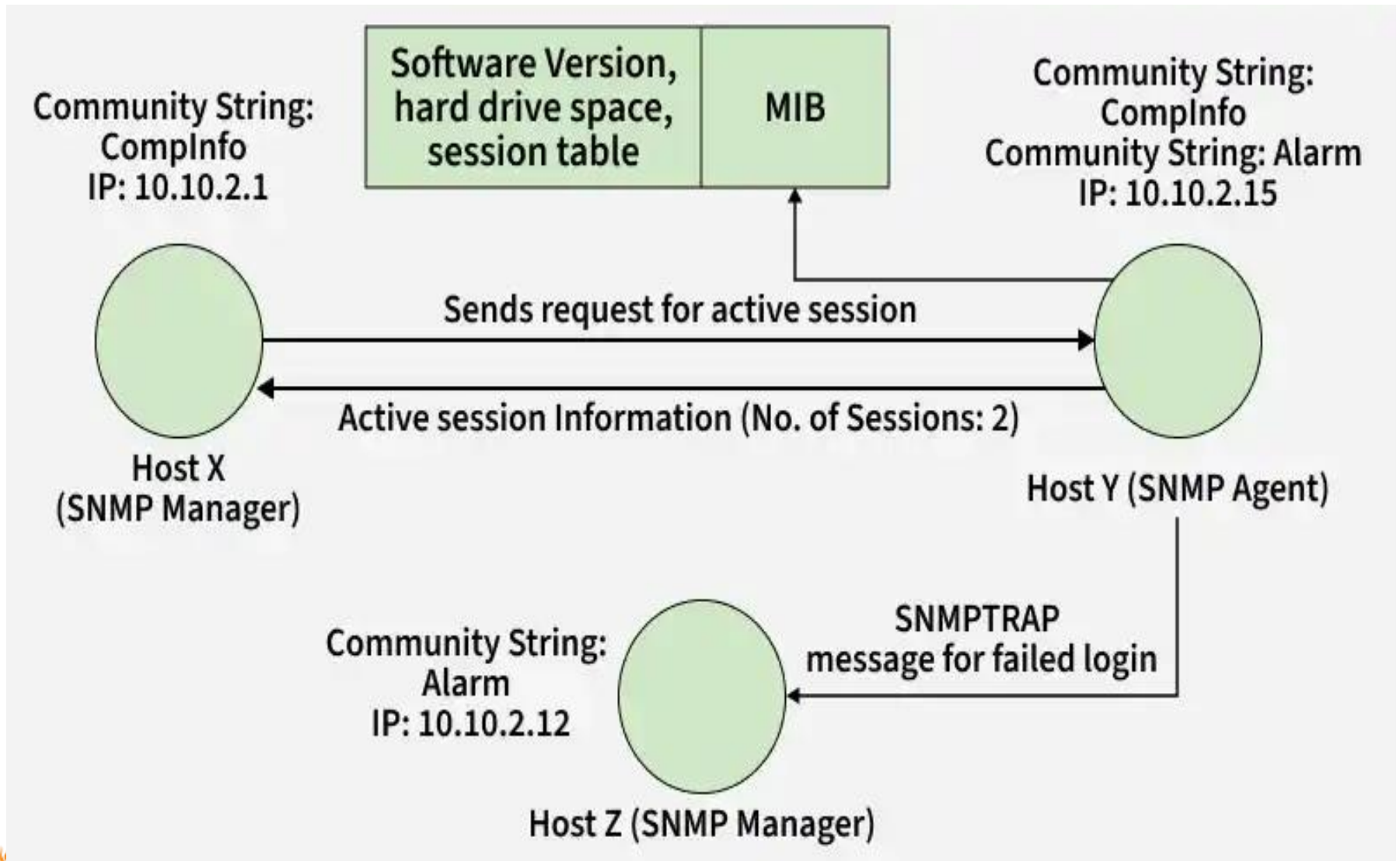
Share name	Type
Public	Disk
Shared	Disk
Printer	Print

The command completed successfully.

2. SNMP Enumeration

- SNMP (Simple Network Management Protocol) is widely used for monitoring and managing network devices such as routers, switches, printers, and servers.
- SNMP enumeration collects device information, routing tables, ARP tables, interface details, running services, and network topology from SNMP-enabled devices.
- SNMP operates on **UDP Port 161** and supports operations such as GetRequest, GetNextRequest, SetRequest, and Trap.
- **Mitigation:** Disable unnecessary SNMP, replace default community strings, restrict access with ACLs, and use SNMPv3 for authentication and encryption.

SNMP Enumeration



SNMP Enumeration commands

- # SNMP enumeration with snmpwalk
- snmpwalk -c public -v1 target-ip
- # Enumerate system information
- snmpwalk -c public -v1 target-ip 1.3.6.1.2.1.1
- # Enumerate network interfaces
- snmpwalk -c public -v1 target-ip 1.3.6.1.2.1.2.2.1.2
- # Enumerate running processes
- snmpwalk -c public -v1 target-ip 1.3.6.1.2.1.25.4.2.1.2
- # Enumerate installed software
- snmpwalk -c public -v1 target-ip 1.3.6.1.2.1.25.6.3.1.2
- # SNMP brute force community strings
- onesixtyone -c community.txt target-ip
- # SNMP enumeration script
- snmp-check target-ip -c public

snmpwalk -c public -v1 192.168.1.20

SNMPv2-MIB::sysDescr.0 =
Linux server01 5.15.0 Ubuntu

SNMPv2-MIB::sysName.0 =
SERVER01

SNMPv2-MIB::sysLocation.0 =
Data Center Room A

SNMPv2-MIB::sysContact.0 =
admin@example.com

SNMPv2-MIB::sysUpTime.0 =
12 days, 4 hours

snmp-check 192.168.1.20 -c public

[*] System Information

Hostname:
SERVER01

Operating System:
Ubuntu Linux

Uptime:
15 days

[*] Network Interfaces

eth0
192.168.1.20

lo
127.0.0.1

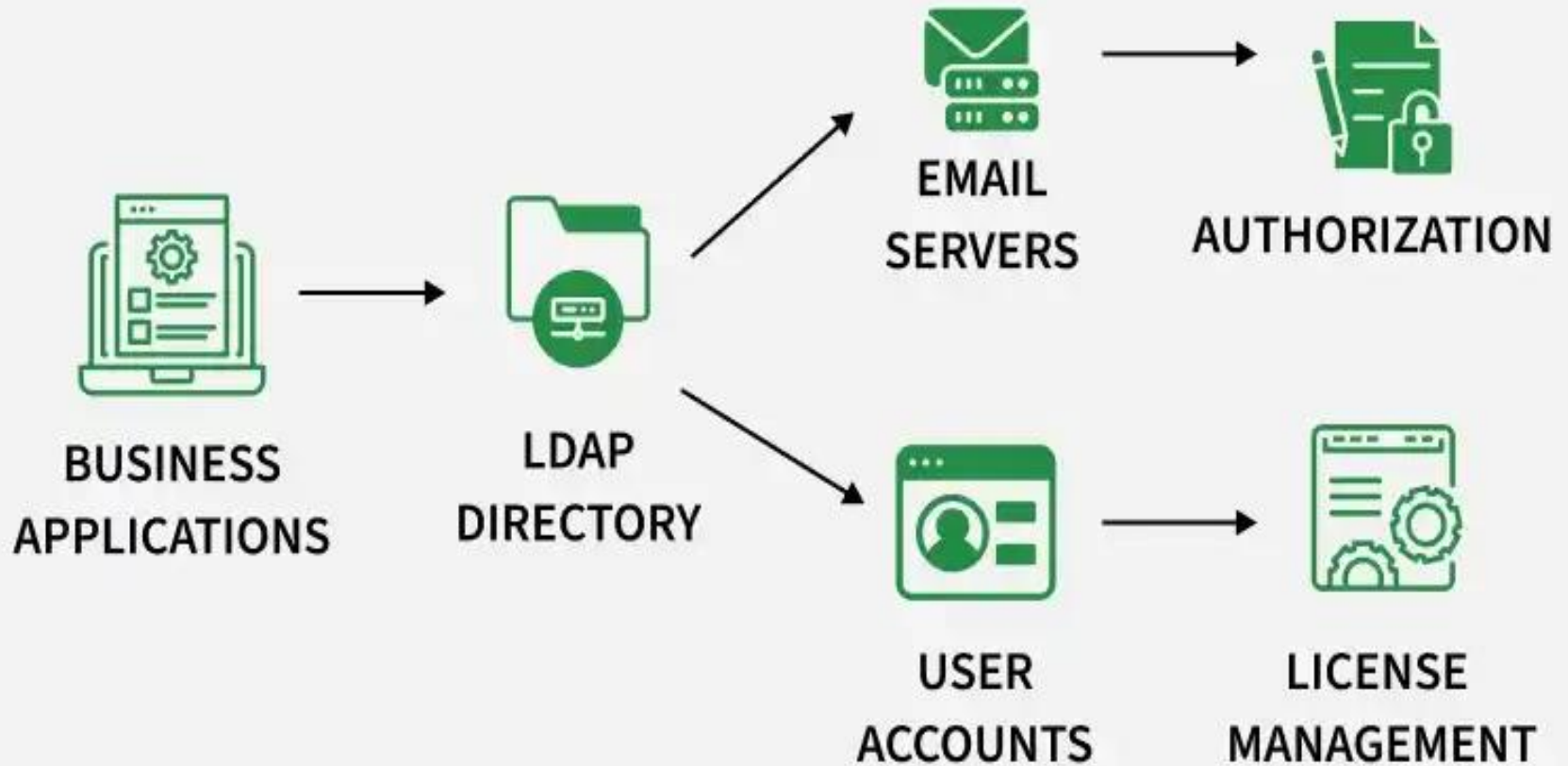
[*] Processes

apache2
mysql
ssh

3. LDAP Enumeration

- LDAP (Lightweight Directory Access Protocol) is used to access directory services such as Active Directory.
- Organizations use LDAP to manage centralized information including users, groups, devices, departments and access policies.
- LDAP enumeration **retrieves usernames, email addresses, group memberships, organizational units, directory structures and other Active Directory information.**
- LDAP uses **TCP Port 389**, while secure LDAP (LDAPS) uses **TCP Port 636** for encrypted communication.
- **Mitigation:** Use LDAPS (SSL/TLS), disable anonymous LDAP queries, enforce strong authentication, and enable account lockout policies

LDAP Enumeration



LDAP Enumeration

- # LDAP enumeration with ldapsearch
- ldapsearch -x -h target-ip -p 389 -s base
- # Anonymous bind enumeration
- ldapsearch -x -h target-ip -p 389 -s sub -b "dc=domain,dc=com"
- # Enumerate domain users
- ldapsearch -x -h target-ip -p 389 -s sub -b "dc=domain,dc=com"
"(objectclass=user)"
- # Enumerate domain groups
- ldapsearch -x -h target-ip -p 389 -s sub -b "dc=domain,dc=com"
"(objectclass=group)"
- # LDAP enumeration with nmap
- nmap -p 389 --script ldap-rootdse target-ip
- nmap -p 389 --script ldap-search target-ip

ldapsearch -x -h 192.168.1.20 -p 389 -s base

dn:

dc=example,dc=com

objectClass:

top

domain

dc:

example

description:

Example Corporation LDAP Directory

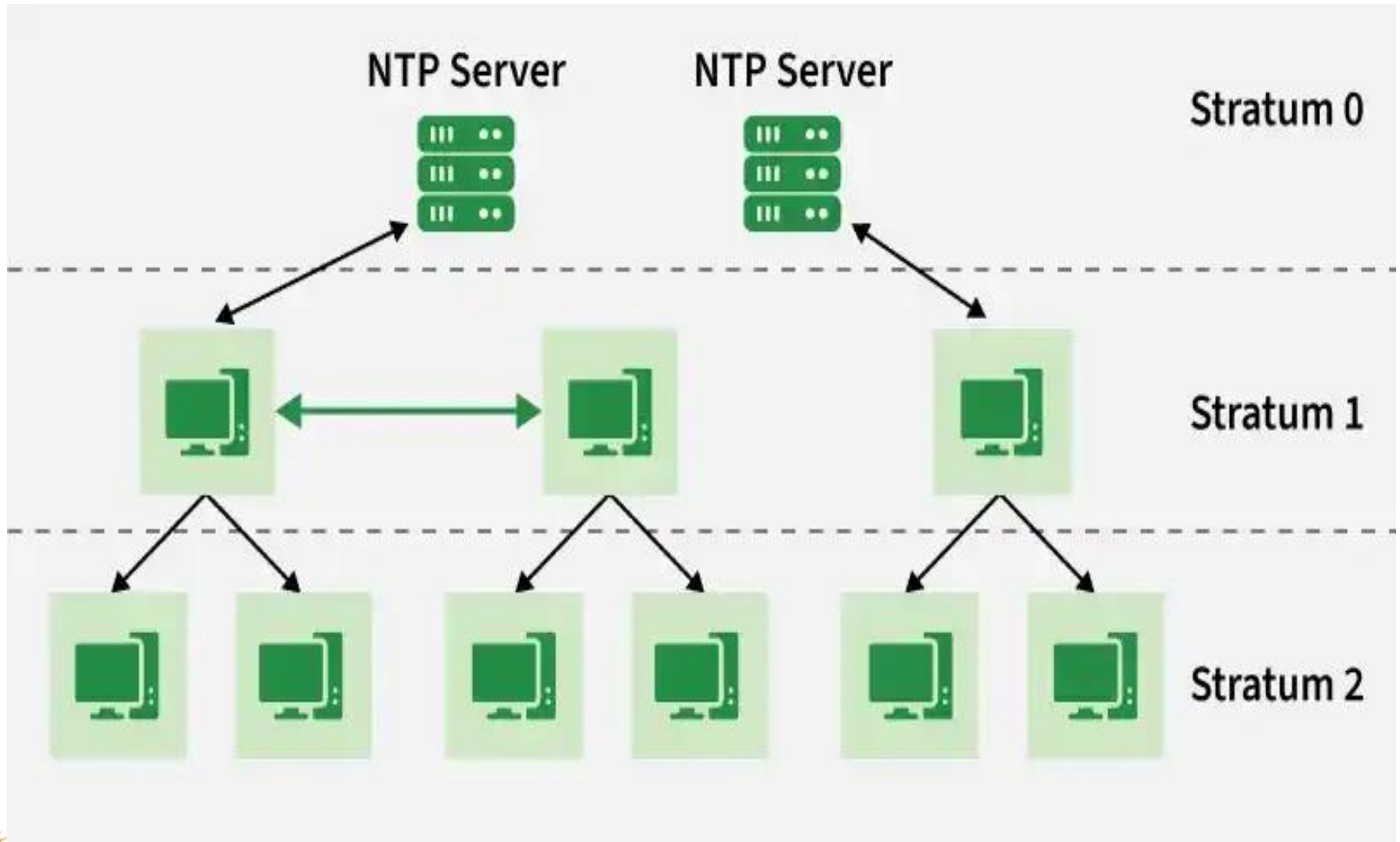
namingContexts:

dc=example,dc=com

NTP Enumeration

- NTP (Network Time Protocol) synchronizes clocks across devices connected to a network.
- Although often overlooked, improperly configured NTP services can expose useful internal information to attackers.
- NTP enumeration reveals connected hosts, client IP addresses, time synchronization peers, operating system details and internal network information.
- NTP operates on UDP Port 123 and can expose network architecture if the service is misconfigured.
- **Mitigation:** Use authenticated NTP, upgrade to secure versions, restrict public access, and enable cryptographic verification.

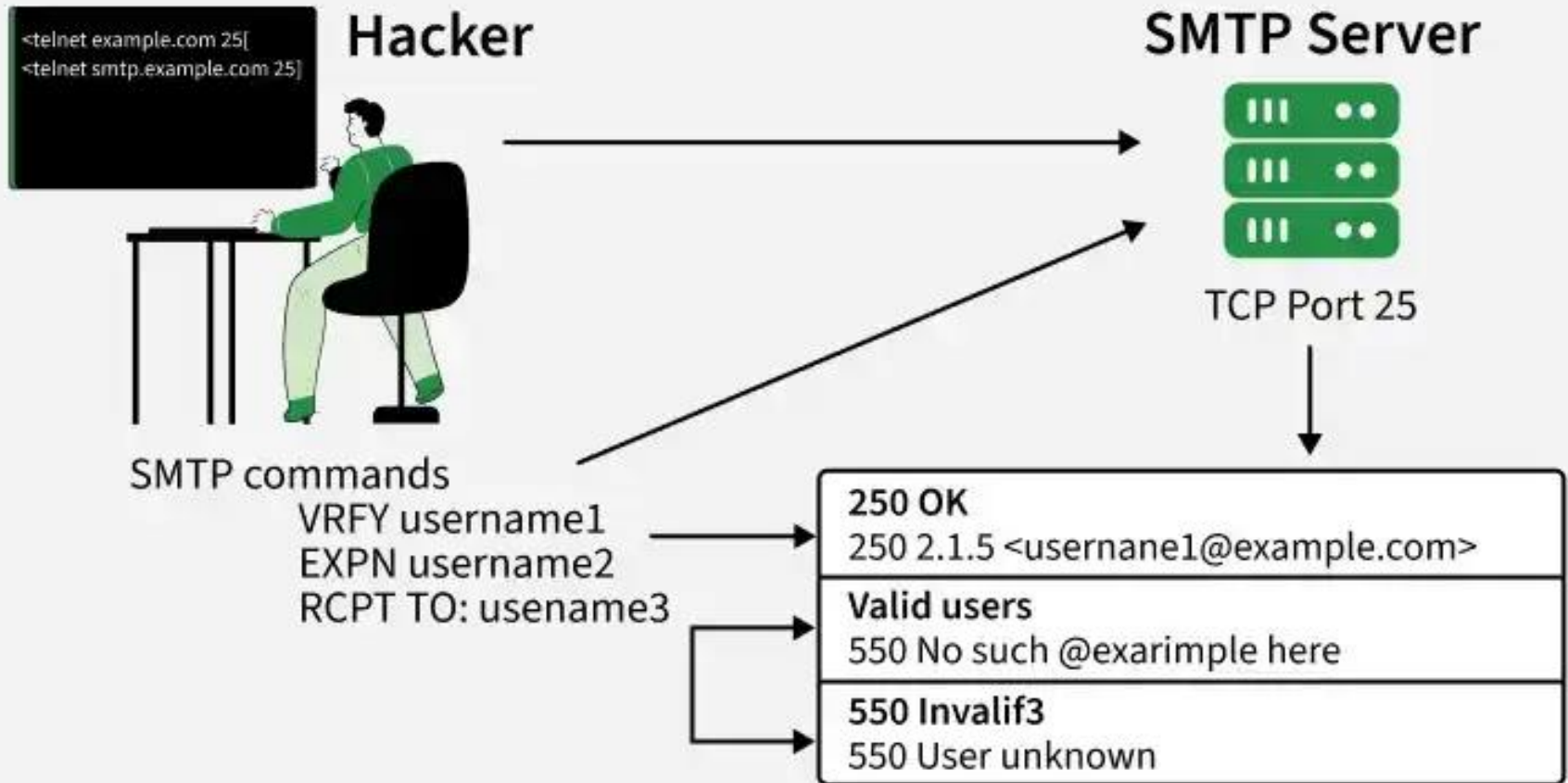
NTP Enumeration



5. SMTP Enumeration

- SMTP (Simple Mail Transfer Protocol) is responsible for sending email messages across networks.
- SMTP servers sometimes reveal valid user accounts by responding differently to specific commands.
- SMTP enumeration identifies valid usernames, mail server details, email addresses and internal mail infrastructure using commands such as VRFY, EXPN and RCPT TO.
- SMTP operates on TCP Port 25 and tools such as Telnet, Netcat, Nmap and Metasploit are commonly used for enumeration.
- **Mitigation:** Disable VRFY and EXPN, prevent open relay, limit connection attempts and minimize information disclosed in SMTP responses.

SMTP Enumeration



6. DNS Enumeration Using Zone Transfer

- DNS (Domain Name System) translates domain names into IP addresses.
- DNS enumeration is used to collect information about an organization's infrastructure, hosts, domains, and network layout.
- DNS zone transfer enumeration reveals domain records, hostnames, IP addresses, mail servers, name servers, and internal network infrastructure
- .
- Common DNS record types include A, MX, NS, TXT and CNAME; unauthorized zone transfers can expose the entire DNS zone database.
- **Mitigation:** Restrict zone transfers to authorized DNS servers, avoid exposing internal records, and implement DNS hardening and continuous monitoring.

DNS Enumeration

01

Malicious Actor

02

Target DNS Server

03

AXFR. Request (Query)

04

Zone Transfer (Response)

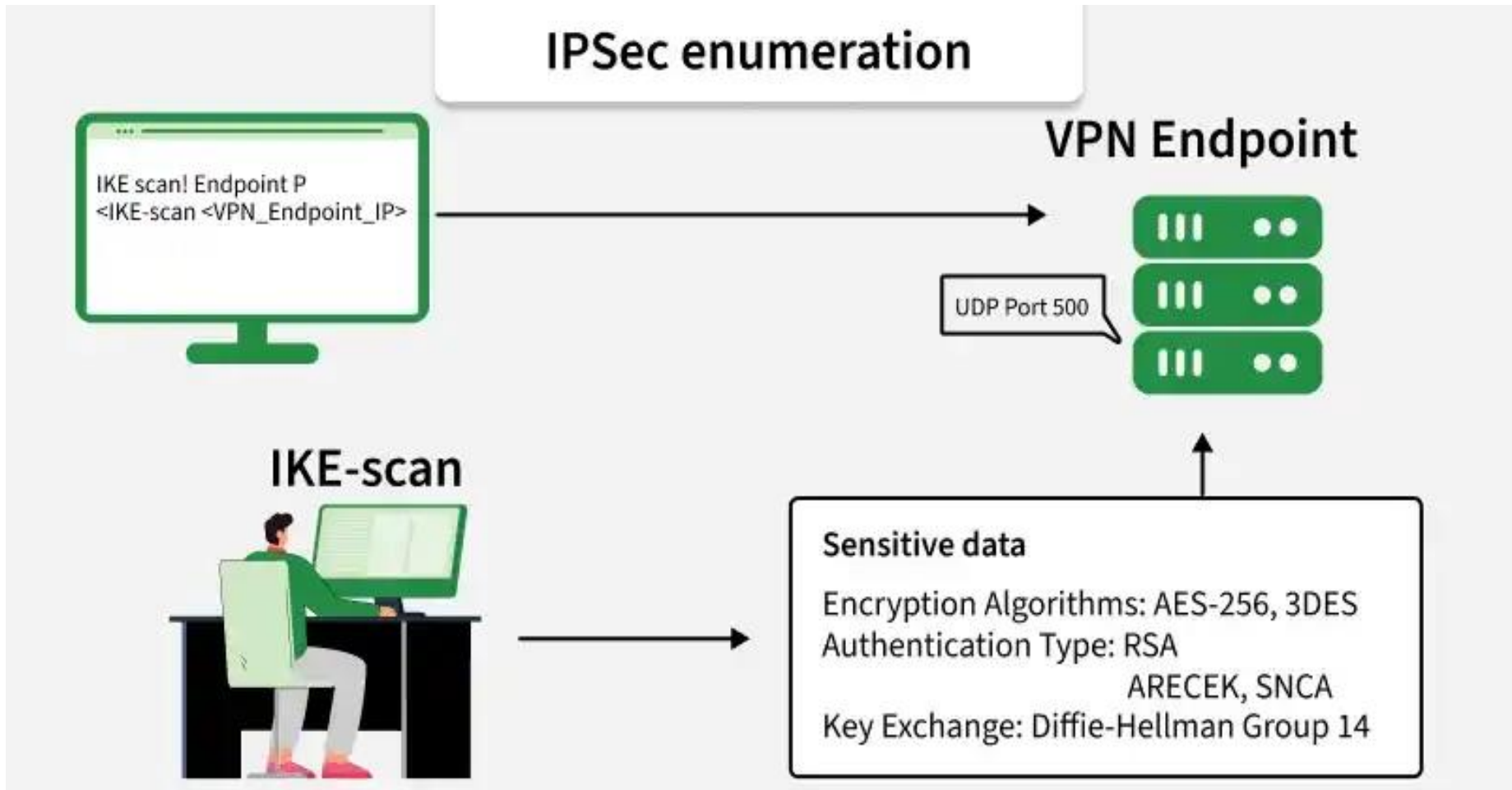
05

Sensitive Data Exposed

7. IPsec Enumeration

- IPsec (Internet Protocol Security) secures network communication and is widely used in VPN deployments. Weak VPN configurations can become valuable attack targets.
- IPsec enumeration identifies VPN gateways, encryption algorithms, authentication methods, hashing algorithms and key exchange configurations.
- IPsec commonly uses UDP Port 500 for IKE (and UDP 4500 for NAT Traversal), allowing attackers to detect VPN services and configurations.
- **Mitigation:** Use certificate-based authentication, enforce strong keys, restrict VPN access with firewall and IP policies and disable weak cryptographic algorithms.

IPsec Enumeration



8. VoIP Enumeration

- VoIP (Voice over IP) enables voice and video communication across IP networks.
- Many VoIP deployments rely on **SIP (Session Initiation Protocol)** for session establishment.
- VoIP enumeration discovers SIP servers, IP-PBX(Private Branch Exchange) systems, gateways, user extensions, and client devices within the voice network.
- VoIP commonly uses SIP on TCP/UDP Port 5060 and SIPS on TCP Port 5061, which can be targeted for reconnaissance and attack planning.
- **Mitigation:** Use SIPS (TLS), require strong SIP authentication, encrypt signaling traffic and implement robust access control and identity verification.

VoIP Enumeration

Hacker Workstation



Query



Protocol

VoIP Server



Extracted

Cisco Unified
Communications Manager



Version
Version: 12.5
IP: 192.168.1.10

Port
5060

Return

User Extensions



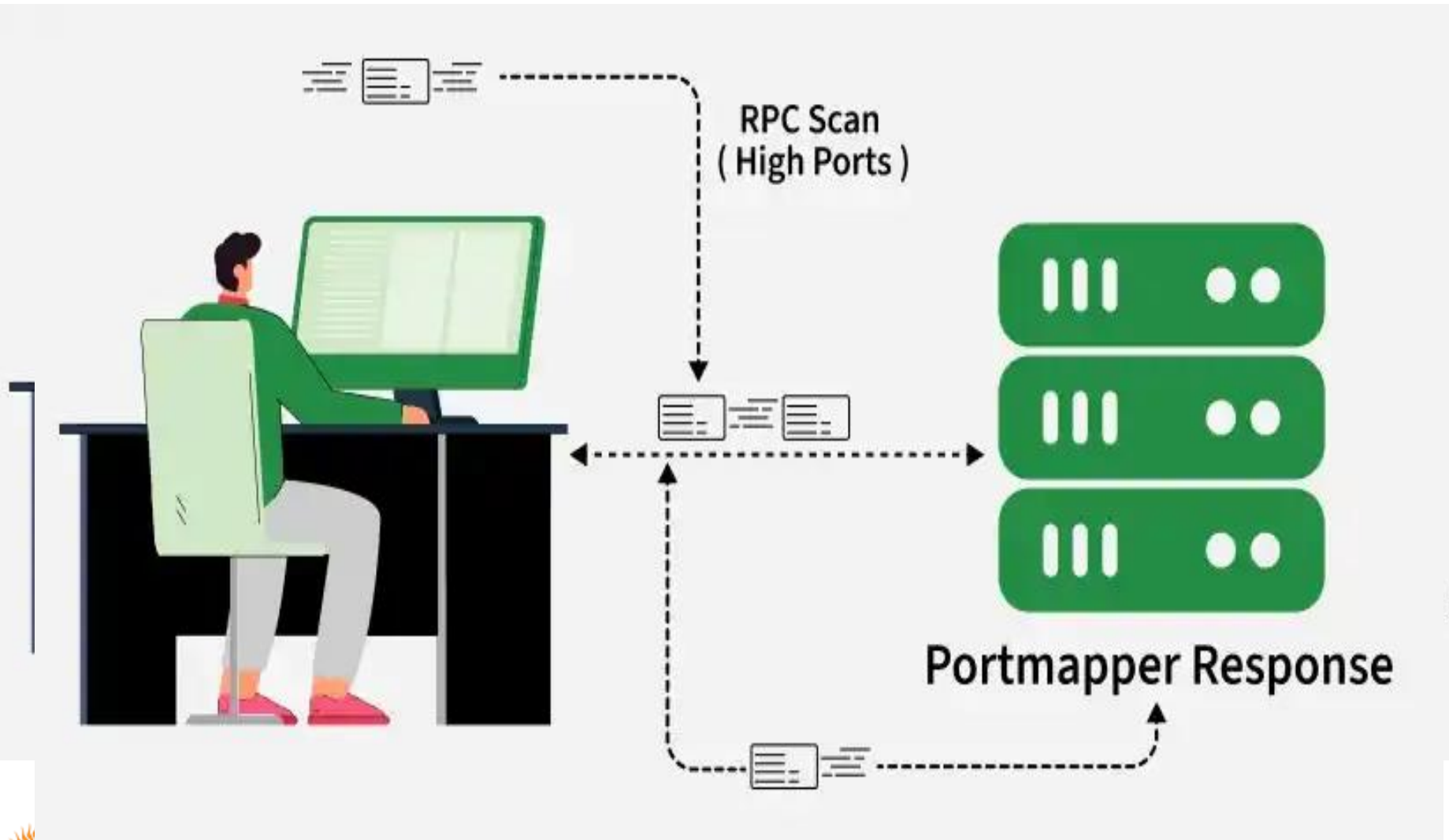
101-John Doe
102 - Jane Smith
103 - Marketing Dept

IP-PBX System Information

9. RPC Enumeration

- RPC (Remote Procedure Call) allows distributed applications to communicate across networks.
- RPC services often expose endpoints that reveal active applications and accessible services.
- RPC enumeration identifies running services, registered endpoints, application interfaces, and accessible communication channels on remote systems.
- RPC commonly uses TCP Port 135 (Endpoint Mapper) and dynamically assigned high-numbered ports for service communication.
- **Mitigation:** Disable unused RPC services, restrict public exposure, apply regular security patches, and enforce firewall rules to limit RPC access.

RPC Enumeration



10. Unix/Linux User Enumeration

- Unix and Linux enumeration focuses on **discovering user accounts, sessions, permissions, and system details.**
- Because Linux environments power servers, cloud platforms and enterprise systems, user enumeration is highly valuable.
- Unix/Linux enumeration reveals logged-in users, active sessions, account names, host information, and system activity using commands such as `who`, `w`, `users`, and `finger`.
- The collected information helps identify valid user accounts, privilege levels and potential paths for credential attacks or privilege escalation.
- **Mitigation:** Keep systems patched, enforce least privilege, restrict unnecessary SUID binaries and limit sudo access to authorized users only.

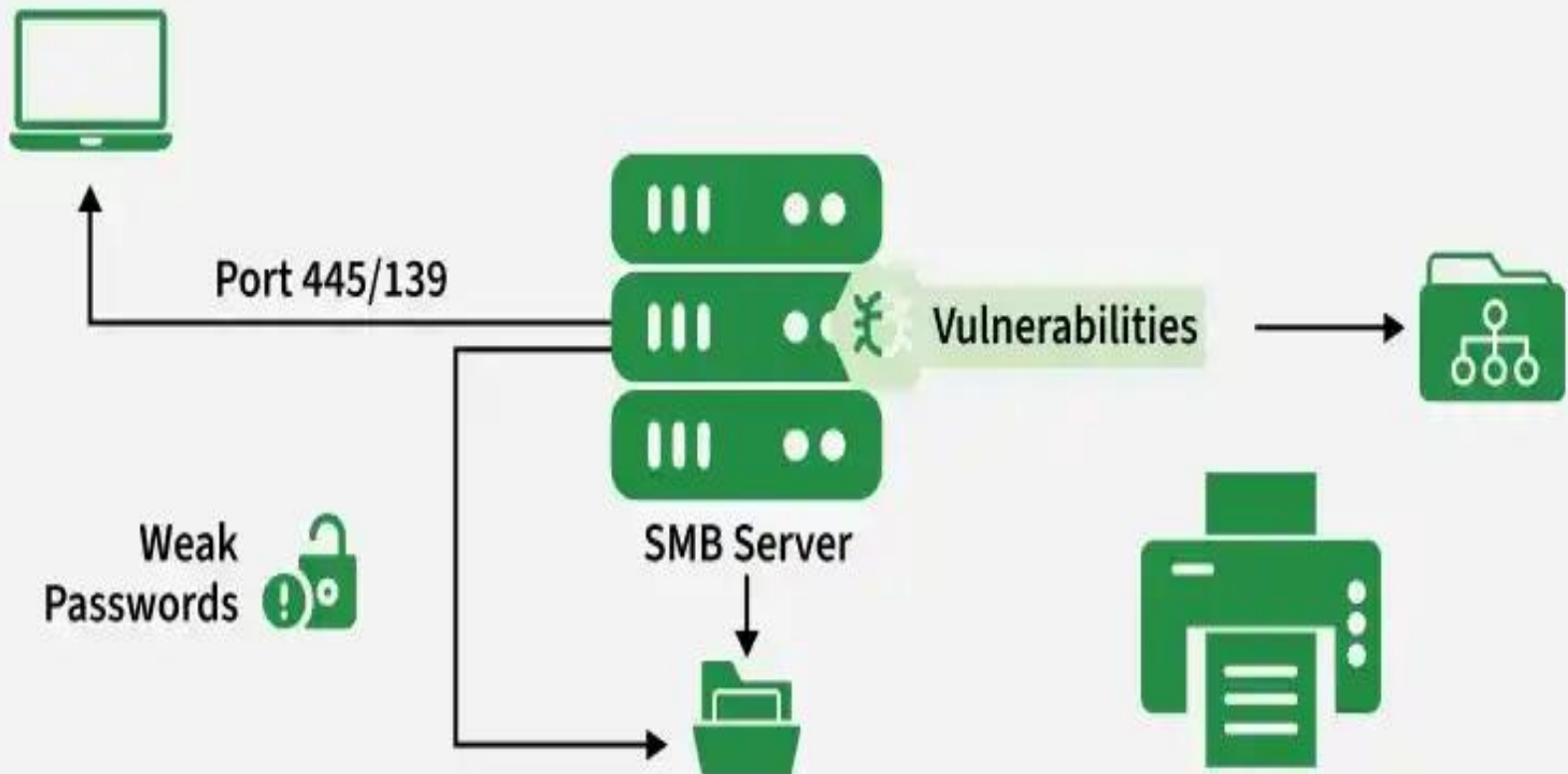
Unix/Linux User Enumeration

```
administrator@GFG0773-LAPTOP:~$ who
administrator :0                2025-08-29 09:32 (:0)
administrator@GFG0773-LAPTOP:~$ w
 11:33:31 up 1 day,  2:02,  1 user,  load average: 0.91, 1.03, 0.98
USER      TTY      FROM          LOGIN@   IDLE   JCPU   PCPU   WHAT
administ :0        :0            Fri09    ?xdm?   3:34m  0.00s  /usr/lib/gdm3/g
administrator@GFG0773-LAPTOP:~$ users
administrator
administrator@GFG0773-LAPTOP:~$ finger
Login          Name            Tty            Idle   Login Time    Office        Office Pho
ne
administrator Administrator *:0            Aug 29 09:32 (:0)
administrator@GFG0773-LAPTOP:~$ last
administ :0        :0            Fri Aug 29 09:32    still logged in
reboot   system boot  5.15.0-139-gener Fri Aug 29 09:31    still running
administ :0        :0            Thu Aug 28 11:07 -  down    (07:47)
reboot   system boot  5.15.0-139-gener Thu Aug 28 11:07 - 18:55    (07:47)
administ :0        :0            Thu Aug 28 10:34 -  down    (00:32)
reboot   system boot  5.15.0-139-gener Thu Aug 28 10:33 - 11:07    (00:34)
administ :0        :0            Wed Aug 27 11:20 -  crash   (23:12)
reboot   system boot  5.15.0-139-gener Wed Aug 27 11:20 - 11:07    (23:47)
gfg0773  tty4        :0            Wed Aug 27 11:16 -  down    (00:03)
```

11. SMB Enumeration

- SMB (Server Message Block) is a protocol used for sharing files, printers, and network resources.
- SMB is heavily used in Windows environments and is also supported on Linux through Samba implementations.
- SMB enumeration identifies shared folders, user accounts, network shares, permissions, authentication details, and server configurations.
- SMB primarily uses TCP Ports 445 and 139, making it a common target for discovering accessible Windows and Samba resources.
- **Mitigation:** Disable unused SMB services, block external access to Ports 139/445, restrict anonymous enumeration, enforce strong authentication and keep SMB updated.

SMB Enumeration



- <https://mycybersecuritypath.com/cybersecurity/footprinting/>
- https://r.search.yahoo.com/_ylt=AwrxdYel2pqWglA9Ae7HAX.;_ylu=Y29sbwNzZzMEcG9zAzEEdnRpZAMEc2VjA3Ny/RV=2/RE=1786579999/RO=10/RU=https%3a%2f%2fwww.youtube.com%2fwatch%3fv%3dMLiudXeudUw/RK=2/RS=y79DvErwbJbMW16iuctkgX.9xQ-
- <https://www.youtube.com/watch?v=P9RgGEWJE7I>
- <https://github.com/SNGWN/CEH-Notes/blob/main/Module%2004%20-%20Enumeration.md>

Thank You
(ujwalar@sies.edu.in)